

מתקפות סיסמאות

מודול 8 — Password Attacks

◀ סוגי מתקפות: מקוון מול לא-מקוון

◀ Wordlists-1 Hashes

◀ Hydra · John · Hashcat

◀ Stuffing מול Spraying

סוגי מתקפות סיסמה

◀ **Brute Force** — כל הצירופים

◀ **Dictionary** — מרשימה (rockyou)

◀ **Password Spraying** — סיסמה אחת נגד רבים

◀ **Credential Stuffing** — פרטים שדלפו

מקוון מול לא-מקוון

◀ **מקוון** — שירות חי (SSH/FTP/web); איטי, רועש, נועל

◀ **לא-מקוון** — סדיקת Hash שהושג; מהיר, שקט

◀ **מקוון** = Hydra

◀ **לא-מקוון** = John / Hashcat

Hash — טביעת אצבע

- ◀ חד-כיווני — לא ניתן "להפוך"
- ◀ סודקים ע"י ניחוש → חישוב → השוואה
- ◀ MD5, SHA, **NTLM** (Windows), bcrypt
- ◀ `hashid <hash>` — זיהוי הסוג (קריטי!)

Wordlists

◀ 14M — **rockyou.txt** סיסמאות (`/usr/share/wordlists`)

◀ **SecLists** — אוסף ענק (`apt install seclists`)

◀ מותאם: `cewl` (מאתר), `crunch` (צירופים)

◀ איכות הרשימה = הצלחת המתקפה

Hydra — מקוון

`hydra -l user -P wordlist ssh://target` ◀

`-L` רשימת משתמשים ◀

`^PASS^ / ^USER^` עם `http-post-form` :web טופס ◀

`-t 4` ⚠ להאטה; רועש ונועל חשבונות ◀

John the Ripper — לא-מקוון

```
john --wordlist=rockyou.txt hash.txt ◀
```

```
john --show hash.txt ◀
```

```
unshadow /etc/passwd /etc/shadow :Linux ◀
```

```
CPU, נוח ואוטומטי ◀
```


Hashcat — הסודק המהיר

◀ מנצל GPU — מהיר בהרבה

◀ `hashcat -m 0 -a 0 hash.txt rockyou.txt`

◀ `-m` : MD5, 1000=NTLM, 1800=Linux, 3200=bcrypt=0

◀ דורש ציון mode מדויק

Stuffing-1 Spraying

◀ **Spraying** — סיסמה אחת נגד כל המשתמשים → נמנע נעילה

◀ **Stuffing** — פרטים שדלפו (מודול 5) נגד היעד

◀ `nxc smb <range> -u users.txt -p 'Winter2024!'`

◀ גשר ל-Active Directory (מודול 13)

הגנה

- ◀ סיסמאות חזקות + מדיניות
- ◀ **MFA / 2FA** — ההגנה החזקה ביותר
- ◀ נעילת חשבון אחרי X ניסיונות
- ◀ Hashing חזק (bcrypt/Argon2 + Salt)

סיכום מודול 8

- ◀ מקוון (Hydra) מול לא-מקוון (John/Hashcat)
- ◀ זיהוי Wordlist + Hash טוב = סדיקה
- ◀ Spraying/Stuffing מנצלים משתמשים+דלף
- ◀ המלץ MFA ונעילה לדוח
- ◀ **תרגול** → practice.md · **פתרונות** → solutions.md